

OWASP Top 10 Risk Mapping

Web Application Security Review & Vulnerability Analysis

Prepared By: Lakshmi Subhaja Kari

Assessment Year: 2026

Target: DVWA on Metasploitable 2

Target IP: 192.168.23.129

Assessment Type: Authorized Security Assessment

1. Overview

This document maps the observations and assessment activities performed during the Web Application Security Review to relevant OWASP Top 10 categories.

The assessment was conducted in an isolated VMware laboratory environment using DVWA hosted on Metasploitable 2.

The mapping distinguishes between **confirmed security observations**, **informational reviews**, and **vulnerabilities that were tested but not confirmed**.

2. OWASP Top 10 Mapping

#	Finding / Assessment	Evidence / Tool	OWASP Category	Risk	Status
1	Outdated Apache/PHP	Nikto	A06 – Vulnerable and Outdated Components	High	Observation
2	Exposed phpMyAdmin	Nikto / Gobuster	A05 – Security Misconfiguration	High	Observation
3	Directory Listing	Nikto / Gobuster	A05 – Security Misconfiguration	Medium	Observation

4	Exposed phpinfo.php	Nikto / Gobuster	A05 – Security Misconfiguration	Medium	Observation
5	HTTP TRACE Enabled	Nikto	A05 – Security Misconfiguration	Medium	Observation
6	Missing Security Headers	Nikto	A05 – Security Misconfiguration	Medium	Observation
7	Authentication Review	DVWA	A07 – Identification and Authentication Failures	Informational	No vulnerability confirmed
8	Session Management Review	Burp Suite	A07 – Identification and Authentication Failures	Informational	No vulnerability confirmed
9	Reflected XSS Test	DVWA	A03 – Injection	Not Confirmed	Not confirmed
10	Stored XSS Test	DVWA	A03 – Injection	Not Confirmed	Not confirmed
11	SQL Injection Test	DVWA	A03 – Injection	Not Confirmed	Not confirmed

3. A06 – Vulnerable and Outdated Components

Finding: Outdated Apache and PHP

Evidence: Nikto web server enumeration

The assessment identified:

- Apache HTTP Server 2.2.8
- PHP 5.2.4

These are legacy software versions and should not be used in a modern production environment without appropriate compensating controls.

Risk

High

Using outdated software can expose systems to publicly known vulnerabilities and increase the likelihood of successful attacks.

Recommendation

- Upgrade Apache to a supported version.
- Upgrade PHP to a supported version.
- Maintain a regular patch-management process.
- Remove unsupported components from production systems.
- Monitor software versions and security advisories.

4. A05 – Security Misconfiguration

Several observations were associated with security misconfiguration.

4.1 Exposed phpMyAdmin

Evidence: Nikto and Gobuster

The phpMyAdmin resource was identified during web enumeration.

Risk

High

Exposing an administrative database management interface increases the application's attack surface and may provide attackers with an additional target.

Recommendation

- Remove phpMyAdmin if it is unnecessary.
- Restrict access to trusted administrative networks.
- Require strong authentication.
- Apply network-level access controls.
- Keep the software updated.

4.2 Directory Listing

Evidence: Nikto and Gobuster

Directory indexing was identified on resources including:

- /icons/

- /doc/
- /test/

Risk

Medium

Directory listing can disclose files, directories and information about the server's structure.

Recommendation

Disable directory indexing unless it is specifically required.

4.3 Exposed phpinfo.php

Evidence: Nikto and Gobuster

The `phpinfo.php` resource was accessible.

PHP information pages can expose detailed configuration information about the server and PHP environment.

Risk

Medium

Information disclosure may assist attackers during reconnaissance.

Recommendation

Remove `phpinfo.php` and other diagnostic files from production environments.

4.4 HTTP TRACE Enabled

Evidence: Nikto

HTTP TRACE functionality was identified as enabled.

Risk

Medium

Unnecessary HTTP methods increase the attack surface and may contribute to security risks depending on the application's configuration.

Recommendation

Disable HTTP TRACE unless there is a documented business or operational requirement for it.

4.5 Missing Security Headers

Evidence: Nikto

Several recommended HTTP security headers were not detected.

Examples include:

- Content-Security-Policy
- X-Content-Type-Options
- Referrer-Policy
- Permissions-Policy
- Strict-Transport-Security where HTTPS is correctly deployed

Risk

Medium

Missing security headers can reduce browser-side security protections and increase exposure to certain classes of attacks.

Recommendation

Implement appropriate security headers based on application requirements and validate them after deployment.

5. A07 – Identification and Authentication Failures

Authentication Assessment

The authentication functionality was reviewed using controlled valid and invalid authentication attempts.

A valid administrator credential was accepted, while an intentionally incorrect password was rejected.

Result

No specific authentication vulnerability was confirmed.

Risk

Informational

Recommendation

Production applications should implement:

- Strong password policies
- Rate limiting
- Account protection
- Secure authentication mechanisms
- Monitoring of repeated failed login attempts

6. A07 – Session Management Review

Assessment

Burp Suite HTTP history was reviewed to identify session-related cookies and their security attributes.

The review considered:

- Session identifiers
- Secure attribute
- HttpOnly attribute
- SameSite attribute

Actual session values were not included in public evidence.

Result

No specific session-management vulnerability was confirmed.

Risk

Informational

Recommendation

Session cookies should use appropriate security attributes, including:

- Secure
- HttpOnly
- SameSite

where applicable.

7. A03 – Injection: Reflected XSS

Assessment

A controlled reflected XSS test was performed against the DVWA reflected XSS functionality.

The normal input was reflected by the application, but the JavaScript test payload did not execute.

No browser alert was observed.

Result

Reflected XSS: Not Confirmed

Risk

Not Confirmed

Recommendation

Applications should still implement:

- Input validation
- Context-aware output encoding
- Secure templating
- Appropriate Content Security Policy controls

8. A03 – Injection: Stored XSS

Assessment

The stored XSS functionality was tested using a normal message and a controlled JavaScript test payload.

The baseline message was stored and displayed successfully.

The JavaScript payload did not execute and no browser alert was observed.

Result

Stored XSS: Not Confirmed

Risk

Not Confirmed

Recommendation

Use context-aware output encoding and input validation to reduce the risk of cross-site scripting.

9. A03 – Injection: SQL Injection

Assessment

A baseline request using User ID 1 returned the corresponding user record.

A controlled SQL injection test using:

`1' OR '1'='1`

was then performed.

The response continued to return only the original user record.

Result

SQL Injection: Not Confirmed

Risk

Not Confirmed

Recommendation

Applications should use:

- Parameterized queries
- Prepared statements
- Input validation
- Least-privilege database accounts
- Secure error handling

10. Findings by Risk

Risk Level	Findings
High	Outdated Apache/PHP
High	Exposed phpMyAdmin
Medium	Directory Listing
Medium	Exposed phpinfo.php
Medium	HTTP TRACE Enabled
Medium	Missing Security Headers
Informational	Authentication Review
Informational	Session Management Review
Not Confirmed	Reflected XSS
Not Confirmed	Stored XSS
Not Confirmed	SQL Injection

11. Priority Order

P1 – High Priority

1. Upgrade outdated Apache/PHP components.
2. Restrict or remove exposed phpMyAdmin.

P2 – Medium Priority

3. Disable directory listing.
4. Remove phpinfo.php.
5. Disable HTTP TRACE.
6. Implement appropriate security headers.

P3 – Lower Priority / Continuous Improvement

7. Strengthen authentication controls.
8. Review session security configuration.
9. Perform regular vulnerability assessments.
10. Repeat testing after remediation.

12. Overall Assessment

The assessment identified several security weaknesses primarily associated with outdated components and web server security misconfiguration.

The most significant observations were mapped to:

- **A06 – Vulnerable and Outdated Components**
- **A05 – Security Misconfiguration**

Authentication and session management were reviewed under **A07**, but no specific vulnerability was confirmed.

Reflected XSS, stored XSS and SQL Injection were tested under **A03 – Injection**, but the performed tests did not confirm successful exploitation.

The assessment therefore demonstrates both positive and negative security results: vulnerabilities and weaknesses should be reported where supported by evidence, while unsuccessful tests should be clearly documented as **not confirmed**.

13. Disclaimer

This OWASP mapping was prepared from testing performed against an intentionally vulnerable laboratory environment.

The target 192.168.23.129 was part of an isolated VMware host-only network used for authorized cybersecurity training.

The testing techniques described in this document must only be used against systems for which explicit authorization has been obtained.

Prepared By: Lakshmi Subhaja Kari

Project: Web Application Security Review & Vulnerability Analysis

Year: 2026